MAN Energy Solutions

Policy Instruction 1
Standard for Information Security

to

Group Policy MAN ES 13.1
Information Security

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

Policy Instruction Creator:	Chitgopekar, FIG
Policy Instruction Owner:	Tomczyk, FI
Area of Regulation:	IT-Organisation
Cleared by Policy Coordinator:	Klinger, FRI
Cleared by Group Tax:	Mederer, FT
Company:	MAN Energy Solutions SE
Classification:	Internal
Version:	1.0
Scope:	MAN ES Group
Applicable as of:	01.03.2023
Applicability to be checked:	28.02.2026
Policy Instruction Approver:	Klöpffer, MAN ES-F

INTERNAL

Content

1. Purpose 3

2. Scope 3

3. Terms, Definitions, Roles and Responsibilities 3

4. Target Group 3

5. Standard for Information Security 4
5.1 Management of Information Security 4
5.2 Requirements of Information Asset Protection 4

6. References 23

7. Annexes 23

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

1. Purpose

Derived from Group Policy MAN ES 13.1 Information Security, this Policy Instruction defines the standard for Information Security within the MAN ES Group that must be adhered to by all MAN ES Group companies.

Based on Group Policy MAN ES 13.1, the Policy Instruction 1 Standard for Information Security sets out the basic principles for all other regulations, security concepts, and specific rules.

They define the minimum requirements for safeguarding the information assets of MAN ES, proportionate to the risk, and refer to the safeguarding and/or the security of all information, irrespective of the form it takes within MAN ES Group.

Policy Instruction 1 takes account of the requirements of standard ISO27001:2005 Annex A (cf. MAN ES 13.1, Section 5.11).

2. Scope

This Policy Instruction applies worldwide to all companies of the MAN ES Group and its employees[1]. It applies directly and does not require any additional Instruction from individual companies within the Group. In the case of companies, in which MAN ES cannot directly enforce the applicability of this Policy Instruction for legal reasons, the Policy Instruction Owner should be consulted to clarify the extent to which this Policy Instruction is applicable. This applies for example to companies that are not wholly owned by MAN ES SE nor associated with MAN ES SE by way of a control agreement.

If the rules contained in this Policy Instruction cannot be implemented at a Group company due to mandatory local requirements, the Group company must inform the Policy Instruction Owner without delay and agree further course of action with him/her. In such cases, the Group company has an obligation to implement a Regulation that is to be agreed with the relevant Policy Instruction Owner and that is as close as possible to the rules contained in this Policy Instruction while taking mandatory local requirements into account.

The English version of this Policy Instruction is definitive.

This Policy Instruction replaces the MAN-Instruction 1 Standard for Information Security V2.0.

3. Terms, Definitions, Roles and Responsibilities

Annexure 1 for the complete information security framework can be found at the additional information „Terms and Definitions to Information Security“.

4. Target Group

Policy Instruction 1 Standard for Information Security is directed at functions responsible for the MAN ES management of Information Security within the MAN ES Group (cf. MAN ES 13.1, Section 6.1).

[1] For the purpose of better readability, gender-specific spelling is not used. All personal designations in this Policy Instruction are to be understood as gender-neutral.

luca.carabelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

5. Standard for Information Security

The Information Security regulatory system comprises Group Policy MAN ES 13.1, the MAN ES Standard for Information Security, and additional subordinate central and decentralized Regulations which govern the principles of Information Security Management (cf. Group Policy MAN ES 13.1) in more detail.

5.1 Management of Information Security

The function and structure of an Information Security Management System (ISMS) are defined in detail in the MAN Instruction 6 or successor Management of Information Security. This includes defining the roles and responsibilities as well as the committees for monitoring and further development of the ISMS.

The procedure for risk management of information assets shall be performed on the basis of the Group Policy MAN ES 5.4 Risk Management Framework of the MAN ES Group. This shall be defined more specifically by the MAN Instruction 6 or successor Management of Information Security with regard to the risks associated with information technology.

5.2 Requirements of Information Asset Protection

The following table defines the MAN ES-specific requirements for safeguarding the information assets in the MAN ES scope of responsibility. These requirements are tailored to divisions and defined more specifically through the use of additional Policy Instructions.

bruno.ceradelli@gm.it
10 Nov 2025 at 09:43 UTC

INTERNAL

Article	Function and Purpose	Regulation
Article 1	Function Segregation of duties and responsibilities Purpose To distribute tasks and responsibilities such that the misuse or unauthorized modification of IT services and systems is limited to the greatest possible extent.	(1) As part of the risk management process, tasks and responsibilities in business processes together with critical functions shall be identified and evaluated by each MAN ES Group Company. The misuse and manipulation of information and IT systems shall be prevented to the greatest possible extent through the separation of tasks.
Article 2	Function Confidentiality agreements with internal/external individuals and companies Purpose Contractual safeguarding of the confidentiality of sensitive MAN ES information.	(1) Each MAN ES Group Company shall ensure that employees, contract partners, and third parties who are granted access to sensitive information in the MAN ES scope of responsibility sign non-disclosure agreements associated in relation to the processed information. (2) Specific non-disclosure agreements must be signed for performance of administrator tasks on IT systems.
Article 3	Function To prevent and detect weaknesses and threats at an early stage Purpose To ensure an optimized approach to security incidents and identification of potential hazards.	(1) The handling of Information Security incidents shall be supported by a security incident management process defined and documented throughout the MAN ES Group, which defines the behaviour of employees, contract partners, and third parties in the event of security weaknesses and security incidents, incl. their escalation. (2) Each MAN ES Group Company shall ensure that the Group-wide procedure is implemented in accordance with the Policy Instruction 3 Information Security Incident Management to MAN ES 13.1. All employees must be instructed and trained in the procedure by the Group Companies.

bruno.ceradelli@dnv.it
10 Nov 2025 at 09:40 UTC

INTERNAL

Article	Function and Purpose	Regulation
Article 4	Function To ensure security in cooperation with suppliers, partners, and customers Purpose To appropriately safeguard information systems, IT applications and infrastructures in the scope of responsibility of MAN ES that are used by, communicated to, managed by, or made accessible to external parties.	(1) Access to MAN ES information shall only be granted to third parties where there is a specific reason and only within the necessary limits and must be restricted to such an extent that it can be monitored and properly logged. (2) The adherence to the requirements of the MAN ES Group concerning confidentiality, integrity and availability of information, IT services and IT systems shall be clearly defined in contracts with external service providers with regard to their tasks. (3) Agreements or contracts concluded with third parties regulating access to and processing of data shall cover all relevant security requirements. Appropriate agreements shall be concluded in the form of contracts.
Article 5	Function Business and IT service continuity management Purpose To ensure an optimized approach concerning IT Service Continuity in case of disaster or emergency.	(1) All MAN ES Group companies shall establish an integrated business and IT service continuity management process. (2) Emergency measures appropriate to the determined risk shall be realized, regularly tested, and adjusted on the basis of a business impact analysis. (3) Information and data protection shall be ensured even in the case of disaster or emergency.
Article 6	Function To evaluate and manage enterprise assets in the sense of Information Security. The classification and identification of information assets. Purpose	(1) Information assets and associated information and communication technology facilities and rooms, incl. their software and supply equipment shall be clearly identified, classified, and managed as inventory stock. (2) Compilation of the inventory shall incorporate all necessary assets and shall be verified and managed on a regular basis. (3) All information assets and associated information and communication tech-

bruno.ceracelli@dnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
	To create basic principles for assessing an appropriate security level at MAN ES.	nology facilities incl. their software and supply equipment shall be assigned to a responsible data/asset owner. (4) All information processed and stored at and/or for MAN ES shall be fully classified and identified with regard to its confidentiality, availability, and integrity in accordance with the Policy Instruction 4 Information Classification to MAN ES 13.1.
Article 7	Function The appointment and hiring of personnel Purpose To ensure that employees, contractors, and third-party users understand their responsibilities with regard to the safeguarding of MAN ES information values. To ensure that personnel possess appropriate expertise corresponding to their intended tasks with regard to the safeguarding of information.	(1) Before taking up a task and/or assuming a function in the MAN ES Group, employees, contract partners, and third parties shall make themselves aware of the policies and guiding principles for Information Security that are relevant to their activity/functional division. Employees, contract partners, and third parties shall be required to commit themselves to adherence to these regulations in their respective contracts. (2) Individuals with access to areas with relevance to information assets (e.g. Data Center, development department) or with access to sensitive information (e.g. personal data) shall separately be required to commit themselves to adherence to the information and data protection requirements.
Article 8	Function The control and management of personnel Purpose To ensure that employees, contractors, and third-party users recognize potential threats to Information Security, understand their requirements when it comes to safe-	(1) Regular Information Security training shall be conducted and documented on a workplace level. Employees shall be informed of changes, news, and threats on a regular basis. (2) Individuals with a supervisory function shall not take on any administrator roles in the same scope of responsibility. (3) Employees performing tasks with a particular impact on Information Security

bruno.ceradelli@gmv.it 10 Nov 2025 at 07:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
	guarding information values, and comply with corresponding Group Policies and Policy Instructions.	interests shall be allocated sufficient time for the proper fulfilment of these tasks. (4) Contacts shall be available outside of normal working hours for critical security issues and to respond in good time, for example, to warnings from facilities that are critical to security. (5) Group Policy MAN ES 13.1 for Information Security which forms the basis for Policy Instruction 1 Standard for Information Security and additional relevant Regulations/Policy Instructions shall be considered an official regulatory system of MAN ES and shall be agreed with employees and service providers as a contractual obligation for adherence. Violations of these Regulations shall be met with appropriate measures under industrial law and/or contractual penalties.
Article 9	Function The hiring, change to the appointment or termination of personnel Purpose To ensure as little impact as possible for MAN ES with regard to the safeguarding of information in case that employees, contractors, and third-party users change the organization or appointment within the organization.	(1) It shall be ensured that in the event of hiring, change to appointment or retirement of personnel, information, plant equipment, devices, and systems are immediately returned to MAN ES and entry and access rights are immediately revoked. This shall also apply to service providers with regard to their personnel where these conduct work for MAN ES as part of their tasks.

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
Article 10	Function Security areas Purpose To safeguard against unauthorized access and damage or interruption to IT infrastructures and information required for MAN ES business and production processes.	(1) Based on the security requirements determined in a risk analysis, appropriate security zones shall be defined and established to offer appropriate safeguarding against unauthorized access, environmental threats, fire, sabotage, power outage, and cooling system outage. (2) The security zones shall be established according to the onion-skin principle. While connecting zones with different protection requirements access shall be terminated, and controlled within the outer zone and set-up newly according to the protection requirements of the inner zone. (3) Access to a security zone shall only be granted where a specific need exists and the approval process shall be fully documented. Zones shall also be safeguarded in delivery areas.
Article 11	Function The safeguarding of information and communication technology facilities Purpose To appropriately safeguard information and communication technology facilities against physical and environmental threats.	(1) Information and components of information and communication technology shall be placed according to the level at which the information must be safeguarded. They shall be safeguarded against unauthorized access, environmental hazards, power outage, and cooling system outage by the use of technical and organizational measures. (2) When using mobile information and communication devices in particular, it shall be ensured that sensitive information cannot be compromised. The need to safeguard the information shall be determined as part of a risk analysis. (3) Supply lines (power and cooling system) which supply information and communication technology components shall be safeguarded against damage.

bruno.ceradelli@dnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		(4) Data and communication lines which transport confidential or strictly confidential information and/or data shall be safeguarded against interception and if necessary, connections shall be encrypted. Data and supply lines that are critical to business operations shall be designed to include redundant lines. (5) Security and supply facilities shall be serviced and maintained such that their availability and completeness is ensured. (6) Suitable processes shall be established for devices meant for reuse, disposal or resale to ensure that all confidential or strictly confidential data and licensed software on devices (fixed or mobile) are removed or securely overwritten. Storage media shall be disposed or destroyed in a way that data cannot be restored. (7) It shall be ensured that there is no unauthorized removal of information and communication facilities, software, or information from the security zones defined for operation or storage. (8) In the case of remote working, it shall also be ensured that appropriate security measures are implemented in accordance with (1) – (6).
Article 12	Function To separate the development, test, and production environments Purpose	(1) Development and test environments shall be separated from the production environment in order to prevent unauthorized access or changes to these systems. (2) A security concept shall also be devised for test networks and a responsible person assigned.

bruno.ceradelli@ynv.it
10 Nov 2025 at 09:43 UTC

INTERNAL

Article	Function and Purpose	Regulation
	To prevent unintended and/or unmonitored changes to productive system environments.	(3) In the event that production data files or copies thereof must be accessed for test purposes, these shall be safeguarded in the same way as with production processes. Use and the reasons for use shall be documented. (4) Test data which represent confidential or strictly confidential information shall be deleted immediately after processing. (5) Comprehensive processes shall be established for the transition from development in the test and in production which safeguards against errors in the production environment.
Article 13	Function To secure the MAN ES network and its interfaces Purpose To safeguard against unauthorized use, interruption, and unauthorized flows of information.	(1) The confidentiality, availability, and integrity of data shall be safeguarded during transportation through the network in accordance with the need to safeguard. Security measures shall be selected according to the nature and composition of the transmission path of the network (wireless LAN, WAN, LAN) and must take account of the need to safeguard the data. Confidential Company data shall be encrypted when being transferred over public networks. (2) With regard to functional use, all network components shall be configured as restrictively as possible and safeguarded against unauthorized access. The principle of minimum authorization allocation shall be applied. (3) For network components that are critical to business, the need for monitoring and logging measures shall be assessed and set up accordingly. Any log data recorded shall be verified on a regular basis, automatically if possible.

bruno.seradelli@gmv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		(4) To allow networks with different security requirements to be connected, a risk analysis shall be conducted. Suitable processes shall be defined and documented on this basis. An approval process shall be established. (5) Access between different networks with different security levels shall be restricted. For the definition of permitted access options to internal resources, a zone concept shall be developed. Networks shall be separated logically according to their security requirements. (6) The security properties, service levels, and administration requirements of all network services shall be determined and documented. Adherence to applicable security requirements in the network shall form part of contracts with external service providers. (7) Remote access of users to systems or applications shall only be permitted by means of strong authentication. (8) All systems connected to the MAN ES network (internal network) must be easily identifiable.
Article 14	Function To safeguard information and data media Purpose To prevent unauthorized publishing, modification, removal, or destruction of MAN ES information.	(1) When exchanging information using portable data media, the data media shall be safeguarded appropriate to their specific need to safeguard. (2) Removable data media shall be handled in accordance with the need to safeguard the data stored on them with regard to logical and physical security. (3) On disposal of data media, it shall be ensured that confidential data is destroyed such that it cannot be restored.

bruno.ceradelli@dnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		(4) Documented procedures for secure handling (storage and distribution) of information (on portable media) shall be established to prevent unauthorized inspection (access), misuse, or manipulation. All employees shall be made aware of the correct handling of information and data storage media. (5) Employees shall undertake to safeguard information and data media against unauthorized access when leaving their work place, even for a short period. (6) Encryption mechanisms shall be regulated in a crypto concept with regard to their application, key management, and legal aspects.
Article 15	Function To safeguard internal and external communication Purpose To prevent leakage or disclosure of MAN ES information.	(1) The transfer of data within the MAN ES network or the external transfer of data from within the network shall only take place via the permitted secure interfaces and in accordance with the corresponding need to safeguard. Regulations shall be documented. (2) When transferring personal data, legal stipulations and the specifications of Group Policy MAN ES 11.7 Protection of Personal Data and Data Protection Organization shall be adhered to. If necessary, the agreement of the person who is the subject of the data being transferred shall be sought in advance. The same also applies to automatic call procedures. (3) Regulations and/or contractual agreements (non-disclosure agreements) shall be concluded concerning the way in which transferred sensitive data must be handled by the recipient, e.g. intended use only, no forwarding to third parties, storage, return, deletion of data.

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		(4) Separate regulations shall be drawn up to cover the risks of electronic data transfer when it comes to sending sensitive information. Users of e-mail systems shall be made aware of the risks of electronic communication. Corresponding training measures shall be documented. (5) Senders and recipients of non-public data shall ensure that the confidentiality of the information is preserved. If the stored data is no longer required, it shall be deleted. Data that are subject to the obligation to preserve records shall be archived accordingly. (6) The storage of business e-mails shall only be permitted in MAN ES environments or environments operated on behalf of MAN ES (such as cloud services with necessary data protection agreements). (7) Access to centrally stored e-mails via public networks shall only be permitted via secure, verifiable connections. Secure authentication procedures shall be used. (8) The use of electronic communication means (e.g. e-mail and Internet) shall only be permitted for business purposes and only via centrally provided Internet gateways or pre-set access secured paths.
Article 16	Function Management of authorizations and passwords Purpose Allocation of access permissions according to the least	(1) A technical policy for access rights shall be established and verified regularly based on business and security requirements. (2) A formal procedure shall be established for the registration and de-registration of users. Registrations and de-registrations carried out shall be docu-

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
	privilege requirement, appropriate documentation and effective access protection.	mented in auditable form. It shall be ensured that users only receive authorization appropriate to the tasks that they are required to carry out (minimum/adequate authorization allocation principle). (3) The allocation of administrative system authorizations shall be carried out restrictively, documented with care, and verified on a regular basis. (4) Privileged user accounts shall not be used for everyday work. (5) Password management stipulations shall be defined centrally and shall be evaluated on a regular basis and be implemented in accordance with the requirements of developing technologies. Passwords shall be managed in accordance with documented procedures. (6) Existing access authorizations shall be reviewed at regular intervals. These intervals shall be determined according to the extent and criticality of the access rights.
Article 17	Function To safeguard electronic business traffic Purpose To safeguard electronic business traffic applications.	(1) Online business services of MAN ES shall ensure the authorization and authentication as well as the confidentiality of stored or processed information to a level that corresponds to the need to safeguard the information. (2) The integrity of MAN ES information that is made available on a publicly accessible system shall be safeguarded to prevent unauthorized modification.
Article 18	Function To safeguard system use Purpose	(1) Where there is a statutory obligation to provide evidence, in the case of statutory business requirements or for the purpose of averting hazards, log data shall be created and stored. Within this, the principle of data economy shall

bruno.ceradelli@dnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
	To identify unauthorized use and modification to systems and applications and their malfunctions.	be applied and, insofar as in accordance with the intended purpose, anonymization carried out. (2) General conditions shall be created to allow security incidents and serious interruptions to MAN ES business processes to be tracked and evaluated via all participating networks, systems, and applications. The system times of all MAN ES systems and network components shall be synchronized if this is technically feasible. (3) Log data and log files shall be retained for a fixed period in case they may be useful in future investigations. Logs shall be safeguarded against unauthorized access and manipulation and shall be deleted upon expiry of the fixed retention period. Personal data shall be deleted as soon as they are no longer required. (4) Employees who are involved in the creation, verification, and evaluation of log data shall be required to sign a written agreement concerning the confidential handling of the data. The evaluation of personal data shall be coordinated and jointly undertaken with the person responsible for data protection and the responsible works council. (5) As a result of a risk analysis the extent and content of required log information shall be determined on the basis of statutory and commercial requirements for the identified systems. As a minimum, information shall be available for appropriate tracking of security incidents. (6) Privileged activities forming part of the management of IT systems shall be logged and fully personalized. The conformity of logging procedures shall be

bruno.ceradelli@gmv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		tested by an independent body against defined procedures on a regular basis. (7) Log files shall be evaluated such that events critical to security are identified in good time. It shall be ensured that personnel are appropriately trained for the evaluation of log information. (8) All access to systems containing sensitive data or functions shall be safeguarded with access control where the identity of the user is determined. (9) IT systems that process information with specific protection requirements shall be located in a dedicated (isolated) environment where possible. Isolation may be effected either physically or logically. Information shall only be exchanged by these IT systems with pre-determined systems. In the event that IT systems and/or applications with a specific protection requirement are to be operated in heterogeneous environments, the resulting risks shall be identified and evaluated separately.
Article 19	Function The use of information and communication facilities and devices Purpose The secure use of information and communication facilities and devices.	(1) Where technically possible, after a set period user inactivity shall automatically result in a block (e.g. screen, smartphone). (2) As a principle, use of personal equipment to connect MAN ES Group IT applications for commercial/business purposes is disallowed. Any deviation to this requirement needs to be evaluated by IT Risk Board and must follow risk acceptance process which is regulated in Policy Instruction 5 Exception Handling (Risk Acceptance Process).

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
Article 20	Function The documentation of the procedures, systems, and functions relevant to the operational security of IT by internal and external IT service providers and the safeguarding of the procedures, systems, and functions relevant to IT by internal and external IT service providers Purpose To ensure the documentation of operational procedures such that in the event of a personnel deficiency or system function error, normal operation can be resumed as quickly as possible. The documentation of operational procedures, system configurations, and business organization shall be safeguarded against unauthorized inspection.	(1) All procedures and systems required for proper operation shall be documented such that limitations to business operations or security on account of missing or inadequate documentation are prevented. (2) In the case of business processes whereby multiple organizational units or service providers regularly collaborate, processes shall be defined and documented such that limitations to business operations or the security of MAN ES on account of inadequate definition or documentation are prevented. (3) It shall be ensured that documentation necessary for operation and recovery of critical assets is available in case of business interruptions (e.g. as printout, encrypted on CD/DVD/USB drives). (4) Documentation shall be safeguarded against unauthorized use according to the corresponding protection requirements.
Article 21	Function Change management for internal IT services and services provided by external service providers Purpose To ensure that changes have as minimal an effect on MAN ES business operations as possible.	(1) Changes to IT services or parts thereof (personnel, processes, hardware, and software) shall always be performed in accordance with standardized change management processes. All changes shall be documented. (2) In the case of changes, the effects on the corresponding business processes shall be analysed, evaluated, and documented as part of the IT risk management process.
Article 22	Function Controlled supply, monitoring, and testing of IT services by external service providers.	(1) In addition to functionality and quantity, the necessary safeguarding of MAN ES information assets shall be clearly regulated in repair and maintenance contracts agreed with third parties and partners with regard to availability, confidentiality, and integrity. The MAN ES regulatory system for Information

bruno.ceradelli@dnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
	Purpose To ensure that the services and scope of supply are defined and can be adhered to by external service providers, that deviations from the agreed services or scope of supply are identified and evaluated, and that suitable countermeasures are implemented.	Security shall be incorporated in a suitable form. (2) To this end, checks and regular reports as proof of the service provider's functioning Information Security Management System shall be evaluated, defined, and contractually agreed. (3) Services provided by the supplier with regard to measures for safeguarding MAN ES information assets shall be documented in full by the corresponding contract partner on the basis of reports and logs and shall be appropriate for ensuring that adherence to the agreed service levels can be tested. (4) In contracts with service providers, MAN ES shall be granted the right to conduct audits at service providers' premises. This must also extend to all subcontractors. (5) In the event that plant equipment, devices, or IT systems are sent away for maintenance or repair by MAN ES or the service provider, all confidential or strictly confidential data located on data media shall be deleted in advance to prevent the reconstruction of the stored data. Companies charged with repair undertake to adhere to the necessary confidentiality agreements. Specifically, it shall be determined that data that are stored externally as part of the maintenance work shall be deleted upon completion of the work and shall not be used for any other purpose.
Article 23	Function To manage capacities for internal IT services and those provided by external IT providers	(1) Capacity utilization for all IT components critical to business shall be documented and monitored on a regular basis. (2) Future capacity requirements shall be determined on the basis of trends and

bruno.ceradelli@dnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
	Purpose The timely identification and prevention of bottlenecks.	requirements in order to rule out bottlenecks and allow advance planning.
Article 24	Function To procure systems on the basis of defined criteria Purpose The definition of and adherence to system requirements for IT services.	(1) It shall be ensured that all new IT systems and services fulfil the requirements of the MAN ES Group with regard to Information Security, specifically Policy Instruction 1 Standard for Information Security. Exceptions shall be evaluated and documented. The MAN ES Standard for Information Security and its additional regulations constitute minimum requirements for proper and secure operation. (2) A secure configuration shall be defined as part of system hardening for business critical systems. Those shall be used as basis for a secure installation and serve as a checklist for monitoring.
Article 25	Function Data backup and recovery Purpose To ensure the restoration of lost or damaged data as quickly as possible on request, as well as outsourcing of data to cover emergency situations.	(1) A concept for data backup and recovery shall be defined for each system. This general concept shall also appoint responsibilities. (2) If data is distributed over different systems, overarching data consistency shall be ensured. (3) In the event of local or mobile data management, critical data shall only be stored as a copy or and only as long as necessary. For permanent storage only central storage systems shall be used. (4) The data security concept shall undergo a detailed test at least once a year. The result of the test shall be documented and stored as proof. (5) The same access restrictions shall apply to the storage location of data

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		backups as for systems on which original data are stored. Moreover, measures shall be taken to safeguard the data backup media against external impacts such as fire, water, theft, or sabotage. (6) Data backup media shall be catalogued and have their completeness and readability tested on a regular basis. These shall be documented in auditable form. (7) The ability to restore data critical to business shall be tested at least once a year. All tests carried out shall be documented. (8) Specific measures shall be established for encrypted data or data media. (9) Data media that are no longer required or have been replaced shall be destroyed to prevent the reconstruction of stored data.
Article 26	Function To prevent malicious software and mobile code Purpose To prevent the intrusion and spread of malicious software/code.	(1) A virus protection policy shall be drawn up by the responsible operator(s), to incorporate multiple testing of all items that may be affected by viruses. (2) A virus scanner shall be installed on each work place computer or server on which data are stored or via which data are exchanged. The virus scanner shall be initiated automatically on system start, shall download updates automatically where possible, and shall be prevented from being shut down during operation. (3) All data traffic from or within public networks shall be automatically checked for viruses by a central virus protection system. Virus protection shall be able to check compressed or encrypted files where technically possible. In-

bruno.ceradelli@gmv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		ternal e-mail traffic shall also be checked by a virus scanner. It shall be ensured that the scanner used for e-mail traffic virus scanning cannot become the victim of an attack itself. Suitable measures to protect the virus scanner shall be taken. (4) A process shall be developed and introduced for correctly dealing with virus-infected content in electronic media such as e-mails or text files. Active content such as in downloads or websites from public networks shall have its system conformity verified by central systems before being transferred to the MAN ES network. (5) Only those services and functionalities shall be made available on the systems (client and server) that are required for the intended purpose. (6) Security software and settings shall be configured such that no modifications are possible by the user and that the function cannot be shut down. (7) IT systems in production environments (such as industrial PCs) shall be safeguarded against malicious software insofar as these systems provide access to the Internet, or mobile data media are used. If this is not possible, these systems shall by isolated as appropriate by means of network separation and deactivation of ports. (8) Mobile devices with access to Company data shall be suitably protected against malicious software and Company data espionage.

bruno.ceradelli@gmv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
Article 27	Function The procurement, development, and maintenance of information systems Purpose To safeguard the procurement, development, and maintenance of information systems.	(1) The procurement of information-processing components (software, systems, networks, telecommunication systems, etc.) shall be subject to a comprehensive release and change management process which shall include a defined procurement and approval process. Predetermined ordering regulations shall be maintained. (2) The consideration of risks and safeguarding requirements shall remain an integral component of the procurement and development processes for new information-processing components (software, systems, networks, telecommunication systems, etc.). (3) A catalogue of requirements shall be compiled at the pre-selection phase, to include the formulation of security requirements. The requirements shall be documented and approved. In the case of software, it shall be documented which versions of executable files have been approved. (4) It shall be ensured that hardware and software cannot be modified or manipulated after their approval. (5) In the event that program errors occur during operation in spite of intensive acceptance tests, these shall be resolved as part of the incident/problem management and release management processes. (6) The installation and/or use of unapproved software shall be prohibited and technically prevented. Approved programs shall be checked for modifications on a regular basis. (7) The use of unapproved software shall be detected by means of regular

bruno.ceradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article	Function and Purpose	Regulation
		checks. The results of these checks shall be documented in auditable form. (8) In the case of software that is developed internally or externally, the requirements of the Standard for Information Security and additional guiding principles shall be taken into account in the development process.
Article 28	Function Continuous improvement Purpose To identify and evaluate deviations and weaknesses as well as ensure their timely resolution.	(1) It shall be possible to obtain and evaluate information concerning technical weaknesses in the systems and applications used at MAN ES in a timely manner. (2) The risk of identified weaknesses shall be evaluated. Measures shall be taken to appropriately address the associated risk. (3) Security patch update, Software/Application version updates will be performed on timely manner to ensure technology security relevance weakness are properly mitigated and systems are secured from cyber-attacks. (4) Organizational structures, roles, responsibilities, and lines of communication shall be defined. (5) In order to identify and tackle attacks and network hacking attempts at MAN ES in a timely manner, systems shall be used to automatically detect and/or prevent attack patterns and hacking attempts. (6) Adherence to Information Security rules and measures shall be verified on a regular basis by an independent body and also in the event of significant changes with an impact on Information Security. These verifications may be carried out by means of audit, by the MAN ES Data Protection Officer, by an independent quality assurance body, and/or by an external expert.

bruno.ceradelli@gmv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article 29	Function Adherence to statutory framework conditions Purpose To ensure the implementation of statutory requirementsand early detection of violations.	(1) On behalf of MAN ES, it shall be identified which laws contain relevant regulations for Information Security and which relevant regulations are to be included. International laws and regulations shall also be included where appropriate. (2) In order to safeguard the rights to use, for example, proprietary software products, procedures shall be implemented in order to ensure adherence to relevant statutory, official, and contractual requirements. (3) Legal obligations to obtain data and documentation shall be identified, and corresponding stipulations for their adherence shall be implemented. (4) A procedure shall be established to ensure that only software with corresponding licenses is used on MAN ES systems. (5) MAN ES Group wide software license management shall be implemented to track all licenses usage at MAN ES organization to ensure only required number of licenses are used and rest are surrender or deactivated to follow software license agreement and eventually save cost to company. (6) The relevant national and international stipulations for data protection shall be adhered to for data protection within the MAN ES Group. (7) An appropriate procedure shall be established to ensure that files violating laws or other relevant regulations or data that are not welcome at MAN ES cannot be accessed via the Internet.

bruno.ceradelli@gmv.it
10 Nov 2025 at 09:49 UTC

INTERNAL

Article 30	Function Adherence to the MAN ES regulatory system for Information Security Purpose To ensure the implementation of Information Security regulations within the Group by employees, to identifydeviations, and to introduce appropriate measures.	(1) Those responsible for Information Security (CISO / Cyber & Information Security Domain Lead & Risk & Information Chapter Lead) shall ensure that the MAN ES regulatory system for Information Security is applied correctly at MAN ES in order to ensure adherence to security regulations and standards. (2) In the event of deviation from or violation of the MAN ES regulatory system for Information Security reasons shall be obtained, measures to prevent violation and deviation shall be developed and introduced, and the effectiveness of these measures shall be verified. (3) A reporting system shall be developed that ensures the transparency of the implementation of the MAN ES regulatory system for Information Security within the MAN ES Group and at IT service providers.
Article 31	Function Verification of Information Security Purpose To identify deviations in the planned implementation and to establish non-compliances in Information Security Regulations.	(1) All working processes, plant equipment, devices, and IT systems shall be checked by means of regular audits to ensure their compliance with the MAN ES regulatory system for Information Security. (2) These verifications shall be traceably documented and the results safeguarded against unauthorized inspection. (3) A verification plan shall be formulated to ensure the completeness of verification aspects and verification objects. (4) Technical Information Security must be assessed by measures such as regularpenetration tests or security audits. (5) The organizational Information Security must be checked by regular process audits such as self-assessments, on-site assessments, management assessments or assessments by external partners.

bruno.ceradelli@gmx.it
10 Nov 2025 at 09:49 UTC

INTERNAL

6. References

Further applicable documents always refer to the current version unless stated otherwise.

- Group Policy MAN ES 5.4 Risk Management Framework of MAN Energy Solutions
- Group Policy MAN ES 11.7 Protection of Personal Data and Data Protection Organization
- Group Policy MAN ES 13.1 Information Security
- Policy Instruction 3 Information Security Incident Management to MAN ES 13.1 Information Security
- Policy Instruction 4 Information Classification to MAN ES 13.1 Information Security
- Policy Instruction 5 Exception Handling (Risk Acceptance Process) to Group Policy 13.1 Information Security
- MAN Instruction 6 Management of Information Security to MAN ES 13.1 Information Security
- Related Document 1 – Exception Handling (Risk Acceptance Process) Form

7. Annexes

The annexes always refer to the current version unless stated otherwise.

- Annexure 1 for the complete information security framework can be found at the additional in-formation „Terms and Definitions to Information Security“ to Group Policy MAN ES 13.1 Information Security

bruno.coradelli@gnv.it
10 Nov 2025 at 09:49 UTC

INTERNAL